

Final GRC Assessment Report : VertexOne Digital Services

1. Executive Summary

The executive-level conclusion is provided in **Deliverable 1 : Executive Summary**.

This report provides the supporting assessment context, methodology, findings, framework analysis, recommendations, and management conclusions underlying the executive summary.

2. Business Context

VertexOne Digital Services is an approximately 1,000-employee organization with global operations across AWS and Azure environments.

The organization operates customer-facing web applications and payment-related services and is pursuing continued enterprise and government-sector growth.

This business context creates requirements for effective information security governance, risk management, regulatory compliance, security monitoring, third-party risk management, business continuity, and demonstrable control effectiveness.

3. Assessment Scope

The assessment covers:

- ISO/IEC 27001:2022 Information Security Management System (ISMS)
- NIST Cybersecurity Framework (CSF) 2.0
- Enterprise risk management
- Security control effectiveness
- GRC gap analysis
- Risk treatment and remediation planning
- Audit and management review activities
- Continual improvement
- Cross-framework alignment between ISO/IEC 27001 and NIST CSF 2.0

4. Assessment Methodology

The assessment used a combination of:

- Document review
- Evidence sampling
- Control assessment
- Risk analysis

- Framework mapping
- Management-level review
- Technical validation
- Gap analysis
- Risk treatment planning

Each framework was evaluated according to its own established requirements and assessment principles.

5. Enterprise Risk Assessment

The consolidated enterprise risk position is documented in:

Deliverable 2 : Final Enterprise Risk Register

The register provides the organization's identified threats, vulnerabilities, inherent risk, control effectiveness, residual risk, ownership, and treatment priority.

The highest-priority current risk is **GAP-01 : Security Monitoring Coverage**, followed by high-priority risks associated with incident response validation and cross-border data protection.

6. Control Effectiveness Assessment

Control effectiveness is documented in:

Deliverable 3 : Control Effectiveness Assessment

The representative assessment identified:

- 3 controls classified as Effective
- 2 controls classified as Partially Effective
- 2 controls classified as Not Tested
- 0 controls classified as Ineffective

The assessment indicates that the principal weakness is incomplete operational verification rather than fundamentally inadequate control design.

7. Framework Assessment

Cross-framework applicability and alignment are documented in:

Deliverable 5 : Framework Applicability & Alignment Matrix

The matrix demonstrates how VertexOne's governance, risk, security, and compliance activities align across:

- ISO/IEC 27001:2022
- NIST CSF 2.0

The cross-framework view helps identify common security outcomes and reduce unnecessary duplication between governance and security activities.

8. GRC Findings and Gaps

The consolidated findings are documented in:

Deliverable 4 : Consolidated GRC Gap Assessment

The principal gaps are:

Gap	Priority	Primary Area
GAP-01	Critical	Security monitoring and MTTD
GAP-02	High	Incident response validation
GAP-05	High	Cross-border data protection
GAP-03	Medium	Remaining ISO control implementation
GAP-04	Medium	Shadow IT discovery

9. Risk Prioritization

The current consolidated prioritization is:

- **Critical:** GAP-01
- **High:** GAP-02, GAP-05
- **Medium:** GAP-03, GAP-04
- **Low / Monitor:** R-004, R-010, R-012, R-015

Detailed risk ratings and residual-risk information are maintained in **Deliverable 2 : Final Enterprise Risk Register**.

10. Risk Treatment

Recommended treatment actions are documented in:

Deliverable 6 : Integrated Risk Treatment Plan

The primary treatment strategy is risk mitigation.

Critical and high-priority issues have defined owners and target completion periods. Risks that have already been effectively treated are placed under an accept/monitor approach with continued management oversight.

The treatment model establishes the following management chain:

Risk → Gap → Treatment → Owner → Target → Verification

11. Improvement Roadmap

The implementation sequence is documented in:

Deliverable 7 : 12-Month GRC Improvement Roadmap

The roadmap prioritizes:

1. Security monitoring and detection
2. Incident response validation
3. Cloud and Shadow IT governance
4. ISO/IEC 27001 control implementation
5. Cross-border data governance
6. Continuous measurement and verification

12. Key Performance Metrics

Management should monitor the following metrics during the improvement cycle:

Metric	Management Purpose
Mean Time to Detect (MTTD)	Measure security monitoring and detection performance
Patch SLA Compliance	Measure vulnerability-management effectiveness
Security Awareness Completion	Measure workforce security-awareness coverage
Control Effectiveness	Measure operational performance of key controls
Incident Response Exercise Completion	Demonstrate response readiness
SoA Implementation Progress	Measure ISO/IEC 27001 control implementation
Risk Treatment Completion	Measure remediation progress
NIST CSF Tier Progress	Measure cybersecurity program maturity

13. Executive Decisions Required

Executive leadership and the Risk Committee should:

1. Approve the 12-month GRC improvement roadmap.
2. Prioritize funding for security monitoring and detection improvements.
3. Require formal testing of incident response and business continuity capabilities.
4. Require completion of outstanding ISO/IEC 27001 control implementation.
5. Maintain management oversight of ISO/IEC 27001 corrective actions and GRC remediation activities.

14. Conclusion

VertexOne Digital Services demonstrates a **credible and operational GRC foundation** across ISO/IEC 27001:2022 and NIST CSF 2.0.

The assessment does not identify a fundamentally broken control environment. Instead, the principal opportunity is to strengthen operational maturity through improved monitoring, testing, measurement, evidence, and continual improvement.

The organization therefore has a clear and actionable path forward:

Close the identified priority gaps → verify control effectiveness → measure performance → maintain management oversight → continually improve.

Successful execution of the roadmap should strengthen VertexOne's audit readiness, cybersecurity assurance, compliance posture, and ability to demonstrate continued progress toward ISO/IEC 27001 certification and increased NIST CSF maturity.

Prepared by: Junior GRC Consultant

Organization: VertexOne Digital Services

Status: Final Report for Executive Leadership and Risk Committee Review